SAM DIRR • OCTOBER 11, 2026 • CSD 370 - MODULE 11 FINAL REPORT

Change Control and Configuration Management

A secure development and deployment blueprint for Mesusa Corporation

FINAL REPORT

Prepared for Moira Bennie, Chief Information Officer
Prepared by George Everett, Senior Developer

EXECUTIVE RECOMMENDATION

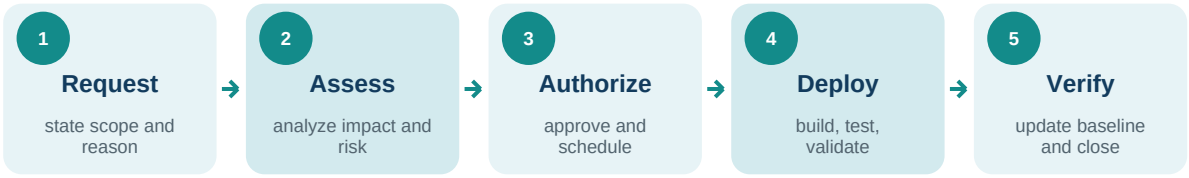
Implement one security-focused change and configuration process

Mesusa Corporation should launch a single, integrated process for change control and configuration management. The process should use risk-based approvals, versioned baselines, automated evidence from existing engineering tools, and a small standing Change Advisory Board (CAB). It will give MeCo a consistent answer to four operational questions: what changed, why it changed, who approved it, and whether the deployed state is safe and recoverable.

Change control	Configuration management
The governed lifecycle for requesting, evaluating, authorizing, scheduling, implementing, validating, and closing a change. A request records the business reason, scope, affected services, risk, testing, rollback plan, ownership, approvals, and result.	The discipline of identifying configuration items, establishing approved baselines, recording versions and relationships, controlling changes, accounting for status, and verifying that actual environments match the approved state.

How the disciplines work together

Configuration management provides the inventory, baselines, and status data that make change control meaningful. Change control protects those baselines by applying approval and risk decisions before deployment. After verification, the release record and configuration baseline are updated. NIST describes security-focused configuration management as a means to maintain security and minimize organizational risk while supporting business services (Johnson et al., 2011).



Configuration management records configuration items, versions, baselines, relationships, and evidence throughout the cycle.

Figure 1. Integrated change control and configuration management lifecycle.

Scope

The process applies to application code, build artifacts, dependencies, infrastructure-as-code, cloud and network settings, database schemas, service accounts, feature flags, policies, and operational documentation. It covers new development, releases, maintenance, emergency remediation, and retirement.

VALUE AND OPERATING MODEL

Control risk without adding unnecessary bureaucracy

Benefit	Why it matters to MeCo	Drawback and safeguard
Traceability and audit readiness	A production state can be linked to a request, owner, approval, evidence, and configuration baseline.	Documentation can feel slow. Use one integrated ticket and automatically attach repository, pipeline, and deployment evidence.
Reduced outage and security risk	Impact analysis, peer review, testing, security gates, and rollback plans expose problems before broad customer impact.	Approvals can delay urgent work. Use preapproved standard changes and a defined emergency lane.
Recovery and incident response	Versioned artifacts and baselines make it possible to restore the last known-good state.	Records can become stale. Reconcile selected services quarterly and act on drift findings.
Cross-functional coordination	Development, operations, security, and business owners share the same decision record and window.	A large committee can become a bottleneck. Keep the CAB small and invite specialists only when required.

Recommended team structure

MeCo should begin with a part-time operating model, not a new department. The CIO should be executive sponsor. An engineering or IT service manager should act as change coordinator and chair a weekly CAB. Dedicate roughly one quarter of a full-time role to coordination during the pilot. The senior developer, platform or operations lead, security representative, and affected product owner should form the core group. A data owner, network specialist, or vendor manager joins only when the change affects that area.

Role	Decision and responsibility
CIO or executive sponsor	Sets risk appetite, approves policy and high-risk exceptions, resolves conflicts, and reviews measures.
Change coordinator	Checks request quality, classifies and routes changes, manages the CAB agenda, and reports process performance.
Technical owner	Completes impact analysis, testing, rollback planning, deployment, validation, and evidence capture.
Security representative	Reviews changes to access, exposure, controls, data flows, or security exceptions.
CAB	Approves normal and high-risk requests within delegated authority and resolves scheduling conflicts.

SECURE DEVELOPMENT LIFECYCLE

Use the process in every lifecycle phase

Security-focused configuration management and change control should not begin at the production-release gate. The following activities connect the process to the secure development lifecycle. The approach reflects NIST guidance to integrate security throughout software development and to manage configurations that affect a system's security posture (Johnson et al., 2011; Souppaya et al., 2022).

Secure SDLC phase	Change control activity	Configuration management evidence
Initiation and planning	Open a request for a new service or major change; identify security, privacy, availability, and ownership needs.	Service record, CI inventory, owners, naming conventions, and initial baseline.
Requirements and design	Review changed requirements, architecture, threat-model findings, vendor choices, and security exceptions.	Versioned requirements, architecture diagrams, data flows, threat model, and control design.
Build and integration	Control code, dependency, pipeline, infrastructure, secrets, and configuration changes through peer review and scans.	Source revisions, dependency versions, build definitions, signed artifacts, and infrastructure state.
Verification and release	Authorize promotion after functional, security, and rollback evidence is complete; schedule implementation.	Test results, approvals, release candidate, deployment manifest, and production baseline.
Operations and maintenance	Process patches, access changes, drift findings, capacity work, vulnerability fixes, and emergency remediation.	Monitoring results, access lists, logs, runbooks, asset relationships, and audit evidence.
Retirement and disposition	Approve decommissioning, data disposition, access revocation, and dependency removal.	Final baseline, archived evidence, inventory update, credential revocation, and disposal record.

Risk-based routing

Standard changes are low risk, repeatable, documented, and preapproved. **Normal changes** need appropriate technical and business approval before implementation. **High-risk changes** can materially affect security, availability, data, cost, or customers and require CAB review. **Emergency changes** protect service restoration or contain an active threat; they require an accountable approver, minimum safe evidence, and a post-implementation review within two business days.

DEMAND AND IMPLEMENTATION

Plan for the volume of controlled change

MeCo has not supplied historical data, so these are planning estimates for one medium-sized service or product team per year. A request is a distinct approved change record; count it once in the primary intake phase even though its evidence continues through later phases. Routine commits bundled into a planned low-risk release are not counted separately unless they carry independent risk or approval requirements. MeCo should recalibrate the estimates after a 90-day pilot.

Phase	Estimated requests per year	Typical demand
Initiation and planning	8-12	New initiatives, major scope changes, environment onboarding, and policy or risk decisions.
Requirements and design	15-25	Architecture, data-flow, vendor, and threat-model changes.
Build and integration	50-80	Code, dependency, pipeline, infrastructure, and configuration changes.
Verification and release	24-36	Planned releases, promotions, release rollbacks, and security-fix releases.
Operations and maintenance	70-110	Patches, access, configuration, vulnerability, capacity, and emergency repairs.
Retirement and disposition	3-6	Component retirement, credential revocation, data disposition, and archival.
Total	**170-269**	**Operations and maintenance should generate the largest share.**

90-day launch blueprint

Days 1-30
Appoint sponsor and coordinator. Define CIs and owners. Publish a short policy, request form, change categories, and CAB schedule.

Days 31-60
Pilot with one product team. Link source control and CI/CD evidence. Create baseline templates. Review every emergency change.

Days 61-90
Expand to other teams. Automate evidence capture and drift reporting. Publish measures and adjust thresholds from the pilot.

Minimum toolset

Use the existing service desk or issue tracker for requests; version control for code, infrastructure, and documentation; protected branches and peer review; CI/CD evidence; a configuration-item inventory; security and dependency scans; and a simple dashboard. Role-based access should prevent one person from both implementing and independently approving a high-risk production change.

GOVERNANCE AND CONCLUSION

Measure whether the process is working

The process should stay light enough that teams use it. The coordinator should reject incomplete requests at intake, not use CAB time to repair them. Requesters need short training on when a ticket is required. Technical owners need to attach testing, rollback, deployment, and validation evidence. Approvers need a simple risk rubric and clear authority limits.

Required request field	Why it is needed
Request ID, owner, service, and affected CIs	Connects responsibility and scope to the inventory and approved baseline.
Reason, category, impact, and security assessment	Lets approvers match the decision to business, technical, and security risk.
Test result, implementation steps, and rollback plan	Shows that the change can be deployed and reversed safely if validation fails.
Approvals, time window, deployment evidence, and closure result	Provides traceability from decision through actual production outcome.

Monthly measures for Moira

Review the percentage of production changes with complete approval and evidence; emergency-change rate; change success and rollback rates; unauthorized or drift findings; average time to approve normal changes; vulnerability-remediation age; and post-implementation review completion. The goal is controlled, visible change with less avoidable risk, not zero change.

Final recommendation

MeCo should approve a 90-day pilot now. Start with an integrated, security-focused process, a part-time change coordinator, and a small CAB. Use existing workflow, source-control, and deployment tools to collect evidence. After the pilot, use actual request volume and quality measures to decide whether MeCo needs a dedicated full-time change manager or additional configuration-management support.

Decision for the CIO
Approve the 90-day pilot, name the coordinator, establish risk categories and CAB authority, and require each production deployment to have identifiable evidence and a recovery plan.

This report uses NIST's security-focused configuration management model as its governance foundation and secure-development guidance to link controls to each lifecycle phase. Microsoft's safe deployment guidance informs the risk-based use of deployment gates, health checks, and recovery practices (Microsoft, n.d.).

SUPPORTING RESOURCES

References

Johnson, A., Dempsey, K., Ross, R., Gupta, S., & Bailey, D. (2011). *Guide for security-focused configuration management of information systems* (NIST Special Publication 800-128). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-128

Microsoft. (n.d.). *Architecture strategies for safe deployment practices*. Azure Well-Architected Framework. Retrieved October 11, 2026, from https://learn.microsoft.com/en-us/azure/well-architected/operational-excellence/safe-deployments

National Institute of Standards and Technology. (2020). *Security and privacy controls for information systems and organizations* (NIST Special Publication 800-53 Revision 5), CM-3 and CM-4. https://doi.org/10.6028/NIST.SP.800-53r5

Souppaya, M., Scarfone, K., & Dodson, D. (2022). *Secure software development framework (SSDF) version 1.1: Recommendations for mitigating the risk of software vulnerabilities* (NIST Special Publication 800-218). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-218

AI assistance disclosure. OpenAI Codex was used to help locate sources, organize and revise the report, and create the visual layout and process graphic. The author reviewed and approved the final content.